

REV	DATA	MOTIVO	ITENS MODIFICADOS
0	19/01/2024	Emissão inicial	
1	08/02/2024	Atender recomendações da auditoria interna	Adicionado a Abuse nas notificações de e-mail, base de conhecimento SOC, anexos e rótulo; e removido o monitoramento Zabbix.
2	22/11/2024	Atualização	Editado 4, adicionado SIEM Wazuh,
3	17/03/2025	Revisão geral	Removido anexo 4.
4	30/09/2025	Atualização de hiperlinks	Itens a, b, e.
5	17/11/2025	Inserido seção 5	Adicionado processo do SOC
6	05/01/2026	Atualização anual	Ajuste do sumário, atualização das figuras 1 e 2 e atualização hiperlink wazuh para ip 10.10.70.114
7	03/02/2026	Ajuste seção 5	Ajustado seção 5 processos

REV	DATA	APROVAÇÃO	
7	03/02/2026	Gerente de SOC	

Este Documento e a informação nele contida são privativos das empresas Interjato Serviços de Telecomunicações Ltda e Interjato Telecom Ltda. A reprodução de quaisquer partes deste Documento está condicionada à autorização por parte das organizações.

Sumário

1. OBJETIVO.....	3
2. DEFINIÇÕES.....	3
3. CONTROLES ASSOCIADOS A ESTA INSTRUÇÃO ¹	3
4. DIRETRIZES.....	3
A) Kaspesky	3
B) SIEM Wazuh	4
C) Notificações de eventos de segurança da informação	4
D) Notificações por e-mail	4
E) Registro de eventos de segurança da informação	5
F) Base de conhecimento SOC	6
G) Comunicação com as partes envolvidas	6
5. PROCESSO.....	6
Passo 1: O Alicerce (Definir a Missão e o Escopo).....	6
Passo 2: O Fluxo de Trabalho Mestre (O Ciclo de Vida do Incidente).....	6
Passo 3: Criar Playbooks Detalhados.....	7
Passo 4: Integrar Frameworks (O Guia de Boas Práticas).....	7
Passo 5: Medir e Automatizar (A Evolução).....	8
6. ANEXOS.....	9
ANEXO 1 – Fluxograma de tratamento de eventos CERT.br.....	9
ANEXO 2 – Fluxograma de tratamento de incidentes .Abuse.....	9

1. OBJETIVO

Estabelecer as diretrizes para o SOC para que os sistemas de monitoramento sejam utilizados adequadamente.

2. DEFINIÇÕES

- **Evento de segurança da informação:** qualquer ocorrência observável em um sistema ou rede.
- **Incidente de segurança da informação:** um evento ou série de eventos que comprometem ou podem comprometer a confidencialidade, integridade ou disponibilidade dos ativos de informação.
- **SI:** Segurança da Informação
- **SOC (Security Operation Center)** ou Centro de Operações de Segurança: setor responsável por centralizar os serviços relacionados à segurança da informação, especialmente aqueles de natureza técnica.

3. CONTROLES ASSOCIADOS A ESTA INSTRUÇÃO¹

- A.5.07 – Inteligência de Ameaças
- A.5.24 – Planejamento e preparação da gestão de incidentes da segurança da informação
- A.5.25 – Avaliação e decisão sobre eventos segurança da informação
- A.5.26 – Resposta a incidente de segurança da informação
- A.5.27 – Aprendizado com incidentes de segurança da informação
- A.5.28 – Coleta de evidências
- A 7.04 – Monitoramento de segurança física

¹ Controles previstos no Anexo A da ISO/IEC 27001

4. DIRETRIZES

São considerados como fontes de eventos de segurança da informação:

A) Kaspersky

Assegura a proteção contínua dos ativos de informação da empresa através da detecção e resposta proativa a ameaças cibernéticas. O SOC utiliza o [Kaspersky](#) como gerenciamento de segurança que permite monitorar os dispositivos da empresa, identificando possíveis ameaças e vulnerabilidades. Além disso, é possível visualizar as licenças de segurança disponíveis, bem como os dispositivos que estão usando essas licenças e o status da segurança.

Para garantir a precisão e a eficiência do gerenciamento de dispositivos e licenças, a nomenclatura dos ativos de informação no [GLPI](#) e Kaspersky são padronizadas.

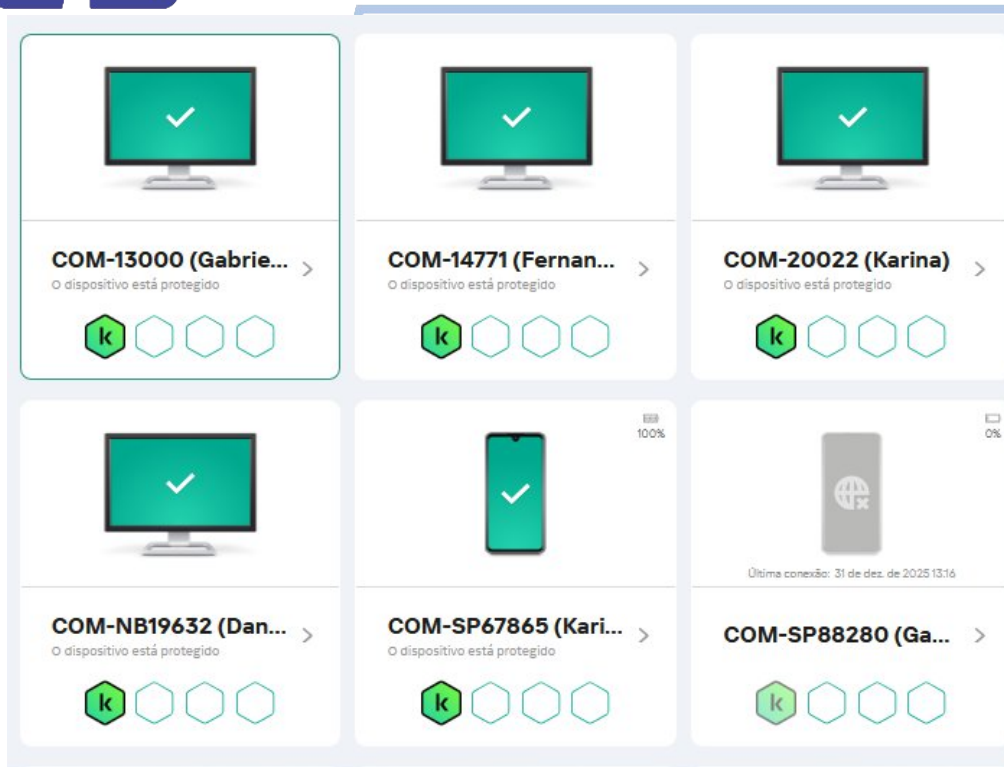


Figura 1 - Monitoramento dos dispositivos no My Kaspersky

B) SIEM Wazuh

O Gerenciamento de Informações e Eventos de Segurança (SIEM) [Wazuh](#) é uma plataforma que agrega e analisa a telemetria em tempo real para detecção e conformidade de ameaças. O Wazuh coleta dados de eventos de várias fontes, como endpoints, dispositivos de rede, cargas de trabalho em nuvem e aplicativo para cobertura de serviço mais ampla.

C) Notificações de eventos de segurança da informação

As notificações de eventos de segurança podem ser feitas anonimamente, para incentivar os colaboradores a reportarem incidentes de segurança, mesmo que não tenham certeza se o evento é realmente uma ameaça.

O [Formulário de Notificação de Eventos SI](#) é encontrado em QR codes pela empresa e no Bitrix. Suas notificações são recebidas no e-mail do SOC, onde são analisadas de acordo com a PG-15.

D) Notificações por e-mail

Os e-mails enviados pela [Abuse](#) e Centro de Estudos, Resposta e Tratamento de Incidentes de Segurança no Brasil ([CERT.BR](#)) informam os responsáveis sobre endereços IP associados a atividades maliciosas com a indicação do problema e a solicitação de que sejam adotadas as medidas necessárias para sua correção. Em anexo às notificações, é enviada a relação dos

endereços IP com os serviços mal configurados e informações sobre os testes realizados para identificação do problema.

As notificações do CERT.br abrangem os seguintes tipos de incidentes de segurança:

- Servidores DNS recursivos abertos (53/UDP)
- Serviço SNMP habilitado (161/UDP)
- Servidores NTP mal configurados (123/UDP)
- Serviço SSDP habilitado (1900/UDP)
- Serviço Portmap habilitado (111/UDP)
- Serviço NetBIOS habilitado (137/UDP)
- Serviço Device Discovery da Ubiquiti Networks habilitado (10001/UDP)

E) Registro de eventos de segurança da informação

A organização do tratamento de evento SI é feito por tarefas no grupo de trabalho [\[Evos SOC\]](#). Após a identificação e classificação do evento, o nome da tarefa no Bitrix segue a seguinte padronização:

[Classificação] Tipo do Incidente / serviço – IP envolvido

A classificação do evento e o tratamento de incidentes de SI são feitos de acordo com a PG-15. Juntamente, a identificação do IP envolvido é feito em contato com analista NOC, caso necessário, ou consultando a documentação existente no Netbox, Osíris e Zabbix.

Todos os passos de tratamento devem ser documentados na tarefa do Bitrix para registro de informações, evidências e relatório pós-tratamento.



Figura 2 - Exemplo de tarefa para averiguação de incidente



F) Base de conhecimento SOC

A base de conhecimento SOC informa referências sobre inteligência de ameaças como grupos de interesse especial, playbooks, informações de monitoramento e tratamento de incidentes de SI no grupo de trabalho [\[Evos\] SOC](#).

G) Comunicação com as partes envolvidas

A comunicação com as partes envolvidas do incidente, dependendo do contexto e das características do incidente deverá ser feita conforme anexo 1 e 2 (se encontram na seção 6. [Anexos](#) deste documento), são feitas pelo e-mail ou atendimento via Whatsapp.

5. PROCESSOS DO SOC

Processos são o sistema nervoso do SOC

Passo 1: O Alicerce (Missão e o Escopo)

Precisamos saber o que estamos protegendo e por quê.

1.1) Ativos Críticos (Crown Jewls)

- Roteadores de Borda (Core da Rede)
- Servidores DNS (Internos e Recursivos)
- Sistemas de Faturamento e Gerenciamento de Clientes

1.2) Riscos Prioritários:

- Prioridade 1: Indisponibilidade (DDoS)
- Prioridade 2: Infecção em massa de clientes (Botnets)
- Prioridade 3: Vazamento de dados de clientes

1.3) Missão: "O SOC Evos existe para detectar e responder rapidamente a ameaças que impactem a disponibilidade da nossa rede e a segurança dos nossos clientes, monitorando, detectando, mitigando, erradicando e protegendo"

Passo 2: O Fluxo de Trabalho Mestre (O Ciclo de Vida do Incidente)

Todo processo de SOC é uma variação de um fluxo mestre. Nós precisamos ter isso definido. É o nosso processo "pai". **Ação (Ciclo Clássico baseado no NIST):**

2.1) Detecção e Coleta: O SIEM gera um alerta.

- Exemplo: "Alerta: Alto volume de tráfego UDP na porta 53 para o IP do Cliente Y."

2.2) Triagem (Nível 1): O Analista N1 pega o alerta

- Pergunta-chave: "Isto é real? (Ou falso positivo?)"
- Pergunta-chave: "Isto é urgente?" (Classificação P1-P5)

2.3) Análise e Escalação (Nível 2): O N1 escala para o N2.

- Pergunta-chave: "Qual é a causa raiz? Qual o impacto total?" **Exemplo:** "Não é um DDoS. É um cliente rodando um servidor de DNS aberto (Open Resolver) e sendo usado em um ataque de amplificação contra um terceiro."

2.4) Contenção: A ação imediata para mitigação.

- **Exemplo:** "N2 solicita ao NOC (Network Operations Center) a aplicação de uma ACL ou rate-limit no IP do Cliente Y."

2.5) Erradicação e Recuperação: A limpeza.

- **Exemplo:** "Equipe contata o Cliente Y para corrigir seu servidor. Após correção, a ACL é removida."

2.6) Pós Incidente (A Lição):

- Pergunta-chave: "Como podemos detectar isso antes? Podemos automatizar a contenção?" **Exemplo:** "Criar uma nova regra no SIEM para detectar padrões de amplificação de DNS antes que se tornem um alerta P1."

Passo 3: Criar Playbooks Detalhados

Possuímos Playbooks, devemos continuar com a construção de novos baseado no ciclo de vida do Passo 2.

Passo 4: Integrar Frameworks (O Guia de Boas Práticas)

Usar frameworks como um checklist para garantir que nosso processos são maduros.

Como usar:



- CIS Controls (O Básico Primeiro): Nossos processos exigem inventário de ativos (CIS 1), logs (CIS e defesas (CIS 10, 12). Usar o CIS para garantir que temos os dados que nossos processos precisam.
- ISO/IEC 27001 (A Gestão): A ISO garante que nossos processos sejam seguidos. Ela exige que tenhamos "proprietários" de processos, que eles sejam revisados (Auditoria Interna) e que haja "Gestão de Incidentes" (Seção A.16).
- MITRE ATT&CK (O Foco no Adversário): Ao invés de processos genéricos como "Alerta de Malware", devemos usar o MITRE. Criar playbooks para técnicas específicas: "T1566 - Phishing", "T1110 - Brute Force", "T1498 - Network Denial of Service". Isso torna nossa resposta muito mais precisa.

Passo 5: Medir e Automatizar (A Evolução)

Um processo que não é medido, não melhora. Processo manual não escala.

Métricas Chave (KPIs) para Processos:

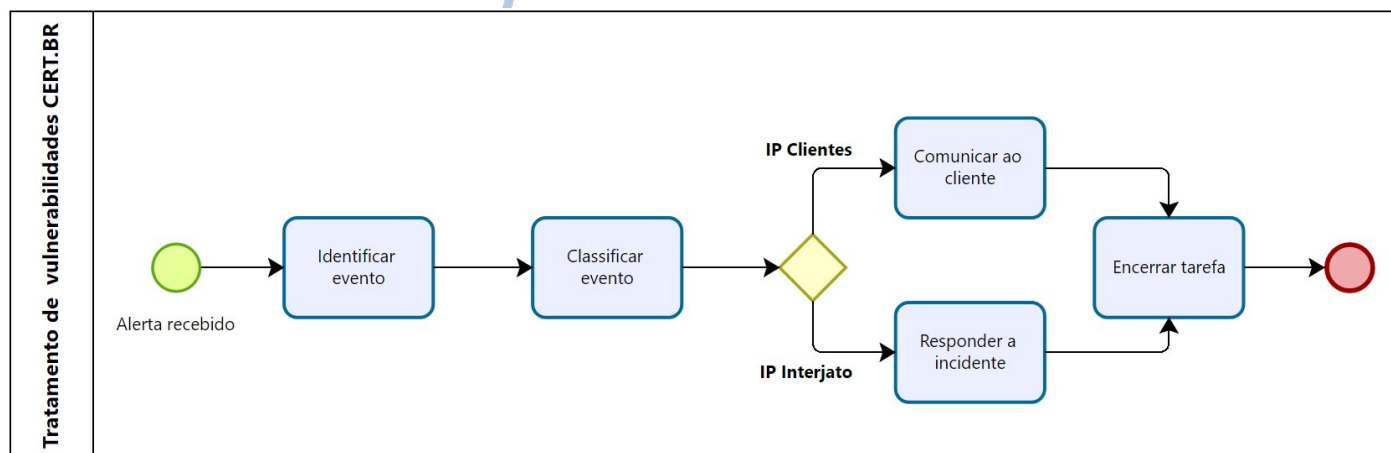
- MTDD (Mean Time to Detect): Tempo médio da ocorrência do evento até o alarme no SIEM.
- MTTA (Mean Time to Acknowledge): Tempo médio do alarme até um analista N1 iniciar a triagem. (Isso mede a eficiência do N1).
- MTTR (Mean Time to Respond/Resolve): Tempo médio da triagem até a contenção do incidente. (Isso mede a eficiência dos processos/playbooks).

Automação (SOAR - Security Orchestration, Automation, and Response):

Isso é bom, principalmente, para triagem de falsos positivos. "Se o alerta X vier do IP Y (que é um scanner conhecido), feche o ticket automaticamente."

"Se o SIEM detectar um ataque de amplificação de DNS (com confiança 9/10), execute o playbook de contenção (aplicar rate-limit no BGP Flowspec) automaticamente e apenas notifique o N2." Isso reduz o MTTR de 30 minutos para 30 segundos.

ANEXO 1 – Fluxograma de tratamento de eventos [CERT.br](https://cert.br).



ANEXO 2 – Fluxograma de tratamento de incidentes [Abuse](#).

